

Security & privacy review — handoff packet

For: the independent security/privacy reviewer (Section-E gate 4). **System:** Steady — self-guided wellness program (Next.js 16 App Router, Node/TypeScript, Postgres/SQLite, deployed on Render). **Prepared:** 2026-07-22 · engineering-drafted from the codebase.

This packet is what to hand the reviewer so they can work without hunting. It describes the system, the data, the controls, and where each lives in the code. It is **not** the review — the reviewer produces that independently.

Before sharing: execute an NDA. Share this packet + repo read access + a **staging** environment with synthetic data. Do **not** share production secret values or real member data (see §11).

1. Engagement scope

In scope: the application's data handling — encryption at rest, secrets management, authentication/session, audit integrity, network/transport headers, backup encryption, third-party data flows, and the voice/biometric boundary.

Out of scope (rely on the vendors' own attestations): Render/Cloudflare/ Stripe/Anthropic/Resend internal infrastructure and their SOC-2s; physical security.

Rules of engagement: active/dynamic scanning (e.g. OWASP ZAP) against the **staging** URL only; passive TLS checks (SSL Labs) against the production domain are fine. No testing against production with real member data.

2. Architecture in one paragraph

A single Next.js app renders all pages and Server Actions. Safety decisions are made by a pure deterministic engine (`src/lib/safety/`) currently in **shadow mode** (governs nothing). Member free text is AES-256-GCM encrypted at the application layer before it reaches the database. An append-only, hash-chained audit log records **coded** safety/consent events (no member text). One subprocessor sees member content (the AI provider, for companion replies); others see only metadata. Nightly backups are `pg_dump` → age-encrypted → Cloudflare R2.

3. Module pointer sheet (where to look)

Concern	File(s)
Field encryption (AES-256-GCM)	<code>src/lib/crypto.ts</code>

Concern	File(s)
Secrets boot-guard (fatal on missing)	src/lib/env-guard.ts
Auth / session (HMAC cookie, logout, caps)	src/lib/auth.ts
Tamper-evident audit hash chain	src/lib/audit.ts
Per-request nonce CSP	src/proxy.ts
Static security headers (HSTS etc.)	next.config.ts
Backups (pg_dump + age + R2) + failure alerts	src/lib/backup.ts , docs/backups.md
Data layer (SQLite/Postgres, ? → \$n)	src/lib/data.ts
Companion → AI provider	src/lib/companion-ai.ts , src/lib/program-plan.ts
Consent/policy versions + copy	src/lib/policy.ts
Compliance status	COMPLIANCE.md ; ADRs docs/adr/0003,0005,0007,0008
Schema	scripts/pg-schema.sql (24 tables)

4. Data inventory

Persisted tables (scripts/pg-schema.sql). "Free-text columns" are AES-256-GCM encrypted at the app layer (enc1: prefix); structured columns (scores, flags, timestamps, ids) are not field-encrypted and rely on platform at-rest disk encryption + access control. All member data is deleted on account deletion except legally-required records (e.g. payment history).

Table	Data class	Sensitivity	Field-encrypted free text?
users	identity, auth material	high	password hash (script), not reversible
consents	consent ledger (version, scope, timestamps)	med	no (metadata only)
screenings	PHQ-9/PCL-5/ITQ/DES answers + scores	high (health)	free-text answers: yes
checkins	daily SUDS/activation/dissociation/sleep	high (health)	structured; notes: yes
therapy_sessions / post_session_checks	session state, SUDS history	high	notes: yes
module_unlocks , alerts	gating + coded alerts	med	no
audit_log	coded safety/consent events	med	no member text by design

Table	Data class	Sensitivity	Field-encrypted free text?
user_profiles, user_triggers, early_warning_signs, safety_plans	trigger notes, safety plan	high	yes
readiness_assessments, care_tracks, care_track_intake, program_plans	routing/plan data	med-high	plan free text: yes
ai_companion_preferences, ai_memory_items, ai_conversations, ai_messages	companion memory + chat	high	message + memory values: yes
subscriptions, payments	billing metadata	med	no (card data never stored — processor holds it)
autonomous_signoffs	clinician verdicts	low	note: yes

5. Subprocessors (third parties that touch data)

Subprocessor	Purpose	Sees member content?	Notes
Anthropic (AI provider)	companion replies, plan drafting	Yes — message content sent for generation	companion-ai.ts, program-plan.ts ; the only content processor. DPA needed.
Render	hosting + managed Postgres	Yes (host of the DB)	at-rest disk encryption; DPA.
Cloudflare R2	off-site backup storage	Encrypted blobs only	backups are age-encrypted <i>before</i> upload; R2 never sees plaintext.
Resend	backup-failure alert email	No member content	ops alerts only.
Stripe (planned; demo provider today)	hosted checkout	Card data only, never stored by Steady	statement descriptor "Steady membership".

6. Encryption & secrets model

At rest (application layer): AES-256-GCM (`crypto.ts`). Key = SHA-256 of `EMDR_DATA_KEY` . Each value: random 12-byte IV || 16-byte GCM tag || ciphertext, base64, `enc1:` -prefixed. Decryption **fails closed** (`[encrypted]` , never throws). Without a key (dev), fields pass through in plaintext — which is why the env-guard makes a missing key fatal in production.

Secrets inventory (values held in the Render dashboard; NOT in this packet):

Secret	Protects	Failure mode if wrong
EMDR_SESSION_SECRET	HMAC-signs session cookies	forgeable cookies → account takeover (fatal at boot)
EMDR_DATA_KEY	field encryption	member free text written plaintext (fatal at boot); rotating it makes existing ciphertext unreadable — treat as durable
DATABASE_URL	Postgres connection	data access
R2_ACCOUNT_ID / R2_ACCESS_KEY_ID / R2_SECRET_ACCESS_KEY / R2_BUCKET	backup storage	backups off if unset
BACKUP_AGE_RECIPIENT	backup encryption (age public key)	the age secret key must never be on the server — restore happens off-box
RESEND_API_KEY	alert email	alerts off
Stripe keys	payments	checkout
Anthropic API key	companion	companion replies

Boot guard: `env-guard.ts` refuses to start in production if `EMDR_SESSION_SECRET` or `EMDR_DATA_KEY` is missing/weak — so a misconfigured "open" deploy fails loudly instead of running silently exposed.

7. Authentication & session (`auth.ts`)

- **Passwords:** script hashes in `users` .
- **Sessions:** a signed cookie — `payload.HMAC(payload)` using `EMDR_SESSION_SECRET` ; verified with `crypto.timingSafeEqual` .
- **Cookie flags:** `httpOnly` , `sameSite=lax` , `secure` in production.
- **Lifetimes:** 7-day idle window (cookie `maxAge`) + 30-day absolute cap (issue timestamp inside the signed token).
- **Revocation:** a per-user token epoch — bumped by "sign out everywhere" or a password change — invalidates all outstanding sessions.
- **Lockout:** login attempt lockout is implemented.
- **Known gap (flag for their opinion):** this is an *interim* model; a managed auth/MFA provider (TOTP 2FA, admin realm, password reset) is planned and is a launch to-do. There is no MFA yet.

8. Audit & logging (`audit.ts` , ADR 0005)

- Append-only, **content-free** records: actor id/role, event family/type, coded target, coded detail — **no member free text** (verified by test).

- **Tamper-evident:** `entry_hash = sha256(prev_hash + canonical(row))`; any edit/deletion breaks the chain, detectable via `verifyAuditChain()`.
- **Concurrency:** the append is serialized (Postgres transaction-scoped advisory lock) so multi-instance writers can't fork the chain.

9. Network / transport (`proxy.ts` , `next.config.ts`)

- **CSP:** per-request nonce; `script-src 'self' 'nonce-...' 'strict-dynamic'`, no `'unsafe-inline'` on scripts (ADR 0008). `style-src` keeps `'unsafe-inline'` deliberately (no script-execution risk).
- **Static headers:** HSTS, X-Content-Type-Options, X-Frame-Options, Referrer-Policy, Permissions-Policy (`next.config.ts`).
- **TLS** terminates at the Render edge.

10. Voice / biometric boundary

- Voice is a free-text-reflection accessibility option only — never SUDS/fit/ safety-gate inputs. **On-device** recognition; **raw audio is never uploaded or stored** — only the member-confirmed transcript (encrypted like any free text).
- Gated behind a distinct versioned consent (`voice-consent-v1.0`), separate from the care-program consent, because voice can be biometric data under **BIPA (IL)**, **My Health My Data (WA)**, **CUBI (TX)**. Currently demo-only.

11. What NOT to share

- **No production secret values** — this packet gives the inventory + handling model, not the keys. Provide staging keys if crypto must be exercised.
- **No real member data** — synthetic/seeded data only for any active testing.

12. Existing automated evidence (context, not a substitute)

gitleaks secret scanning, `npm audit`, Dependabot, axe-core WCAG gate — all in CI. Optional supporting artifacts to request: an OWASP ZAP scan (staging) and an SSL Labs record (production domain).

13. Expected deliverable & how it gates launch

A signed report with findings ranked by severity + a remediation list. **Critical/high findings block Phase-2 activation** (the first time the safety engine governs a real member) per the staged-validation protocol. This gate is independent of the clinical sign-off (already done) — both must be satisfied before the founder flips `EMDR_AUTONOMOUS_SAFETY`.

14. Access checklist to grant the reviewer

- ☐ NDA executed.
- ☐ Repo read access + this packet.
- ☐ Staging environment URL + test credentials (synthetic data).
- ☐ Production domain name (for passive TLS/SSL Labs only).
- ☐ DPA list for subprocessors (§5) for their paperwork review.
- ☐ A named engineering contact for questions.